

Plantilla: Política de seguridad TI

Documento editable para definir la política de seguridad informática de tu empresa. Completa los campos entre corchetes [] con los datos de tu organización y hazlo aprobar por dirección.

1. Propósito

Esta política define las normas de uso y protección de los sistemas de información de [nombre de la empresa]. Su objetivo es proteger la confidencialidad, integridad y disponibilidad de los datos de la organización, sus clientes y empleados.

2. Alcance

Aplica a todos los empleados, contratistas y terceros con acceso a los sistemas, redes, equipos y datos de [nombre de la empresa], así como a cualquier dispositivo personal usado para fines laborales (BYOD).

3. Contraseñas y autenticación

- Longitud mínima de 12 caracteres, con gestor de contraseñas corporativo.
- Prohibido reutilizar contraseñas entre cuentas personales y corporativas.
- 2FA (doble factor) obligatorio en correo, acceso remoto y administración.
- Cambio de contraseña inmediato ante sospecha de compromiso.
- Las cuentas de administración nunca se comparten y se auditan trimestralmente.

4. Accesos y permisos

- Principio de mínimo privilegio: cada persona solo accede a lo necesario para su puesto.
- Revisión de permisos al cambiar de rol y baja inmediata de accesos al salir de la empresa.
- Acceso remoto únicamente mediante VPN corporativa aprobada.
- Acceso de terceros (proveedores): temporal, por proyecto, con aprobación de dirección.

5. Protección de datos (RGPD)

- Los datos personales solo se tratan para finalidades legítimas y documentadas.
- Cifrado de datos personales en reposo y en tránsito.
- Derechos ARCO (acceso, rectificación, cancelación, oposición): canal único de solicitudes.
- Registro de actividades de tratamiento actualizado.
- Notificación de brechas a la AEPD en menos de 72 horas si hay riesgo.

6. Correo electrónico y phishing

- Nunca enviar contraseñas, datos bancarios o documentos sensibles por correo sin cifrado.
- Ante correos sospechosos: no pinchar enlaces, no descargar adjuntos, reportar al responsable.
- Prohibido usar el correo corporativo para cuentas personales o suscripciones ajenas al negocio.
- Filtros antispam y anti-phishing activados a nivel de dominio.

7. Uso aceptable de Internet y dispositivos

- Uso ocasional y razonable de Internet personal, nunca para actividades ilegales.
- Descargas de software solo desde fuentes oficiales y con aprobación.
- Los portátiles corporativos se entregan con cifrado de disco activo (BitLocker/FileVault).
- Prohibido instalar software no aprobado en equipos corporativos.

8. Copias de seguridad

- Copia diaria de datos críticos, verificación semanal y prueba de restauración trimestral.
- Copia fuera de línea o inmutable protegida frente a ransomware.
- Responsable de backups: [nombre/cargo].

9. Gestión de incidentes

- Todo incidente de seguridad se reporta al responsable de TI en < 1 hora.
- Clasificación: bajo / medio / alto / crítico, con tiempos de respuesta definidos.
- Registro de incidentes con lecciones aprendidas.
- Contacto de emergencia: [teléfono / email del responsable].

10. Aprobación

Cargo	Nombre	Firma	Fecha
Dirección			
Responsable TI			
RRHH			

Documento modelo de Forj. Personalízalo y adapítalo a tu organización; un profesional puede revisarlo en [1 hora de consultoría].